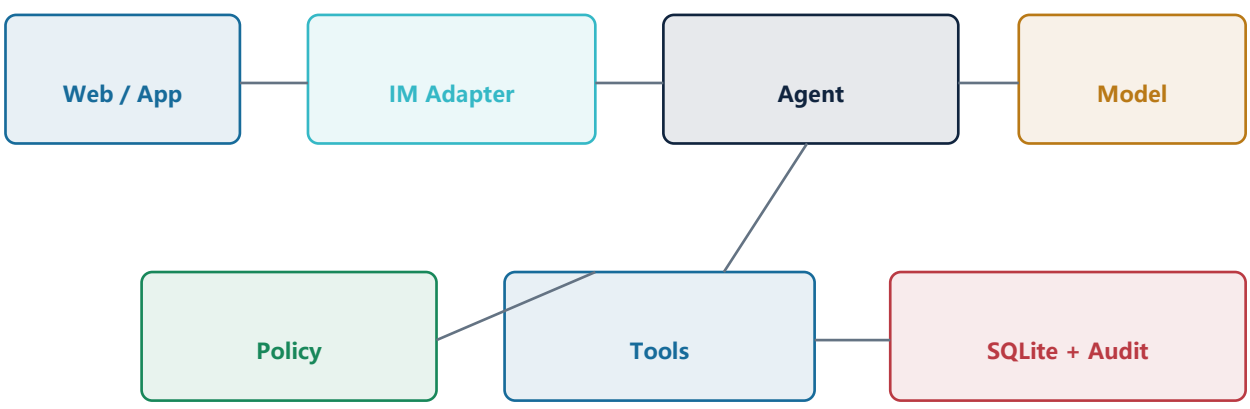
AI BANKING AGENT

众安 Agent

面向众微银行移动端的 AI Banking Agent · 系统架构 · 核心算法 · 安全设计 · IM 接入 · 部署验收



统一链路：接收 -> 识别 -> 规划 -> 策略 -> 执行 -> 审计

提交材料：技术文档（PDF）

版本 1.1 · 2026-10-31 · FinTechathon2026

本文件将银行功能、AI 规划和服务端策略放到同一条可验收链路中：自然语言进入后，先读取账户事实，再生成计划，随后按节点策略执行并留下审计回执。

目录

1. 项目结论与范围
2. 系统架构与运行时
3. Agent 意图理解与任务 DAG
4. 权限策略与安全设计
5. SQLite 金融档案与数据一致性
6. IM 渠道接入与跨渠道确认
7. 语音与模型服务
8. 敌对性审查结果
9. 部署、测试与评审验收

审查口径

文档按代码、数据库、接口和当前验收材料逐项核对。评审重点放在权限语义是否与执行行为一致、模型是否能绕过服务端策略、任务失败后的状态是否可复原、IM
重放是否会重复执行，以及材料中是否把展示状态写成了真实能力。

1. 项目结论与范围

众安 Agent 是面向众微银行移动端的 AI Banking Agent：银行业务工作台与对话编排层的组合。银行功能用独立页面呈现，AI 对话只承担自然语言入口、查询编排、动作计划和结果回执。账户、交易、订阅、贷款和理财档案使用 SQLite 维护，模型不直接改库。

展示范围

- 账号：银行卡列表、账户详情、额度、卡片服务和逐笔流水。
- 资产：总资产、总负债、净资产、可用授信和众微银行账户树。
- 收支：200 条三个月流水，按月折叠，支持平台、方向、分类和日期筛选。
- 贷款：贷款产品、额度测试、贷款账户、申请和还款流程。
- 理财：产品目录、收益率、风险等级、详情与申购流程。
- 服务：预支付项、订阅管理、生活缴费、定时转账和执行回执。

关键运行事实

项目	实现口径	验收证据
数据库	17 个账户、200 条三个月流水、7 个生效订阅	npm run db:check
IM	Webhook + 企业微信回调/出站，票据跨渠道回跳	npm run im:check
语音	Qwen3-TTS 0.6B，7861 端口，9 音色	/api/tts/health
前端	桌面 + 竖屏独立页面，默认浅色专注模式	npm run smoke

技术选型

层面	选型	选型理由
运行时	Node.js 24 + node:sqlite（DatabaseSync）	零 npm 运行时依赖，供应链面收敛到开发工具链
前端	单页 index.html + 分层 CSS + hash 路由	无构建步骤，离线可用，冒烟可断言
策略引擎	服务端三色策略 + 一次性票据 + SHA-256 审计链	可信边界固定在服务端，界面不可越权
模型	OpenAI 兼容网关，按用户可覆盖	免费默认模型可用，自定义网关可升级
IM	自研 Webhook 适配器 + 企业微信 AES 适配器	同一 Envelope，跨渠道确认语义一致
语音	Qwen3-TTS 0.6B 本地服务	离线中文播报，不依赖云厂商配额

2. 系统架构与运行时

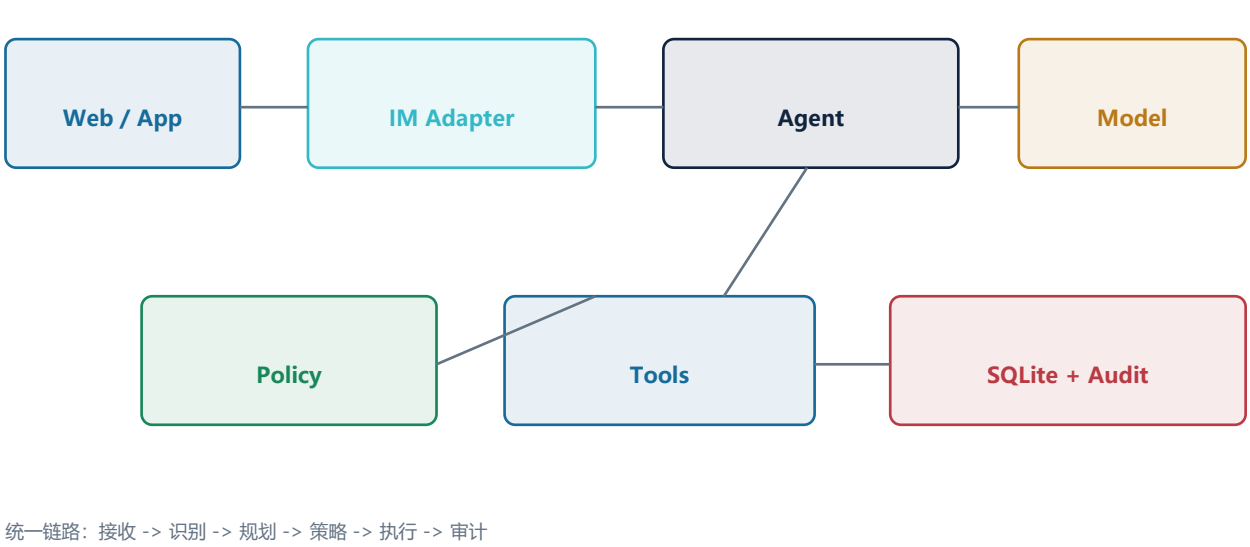


图 1 系统由渠道、Agent、模型、策略、工具、数据和审计组成闭环。

运行时分层

层	输入	输出	不负责什么
渠道适配	HTTP/JSON/XML、签名、消息 ID	统一 Envelope	不判断权限，不直接写账
Agent 编排	文本、页面上下文、历史草稿	Intent、TaskPlan、回执	不凭模型口述确认结果
策略引擎	节点、金额、账户归属、用户策略	green/yellow/red + ticket	不渲染界面
执行器	通过校验的节点	事务结果、业务引用	不重新解释自然语言
审计与熔断	每一步事件	链式记录、circuit_open	不改变业务事实

一次请求的时间线

```
channel.receive -> normalize -> injection_gate -> intent.resolve -> facts.query -> plan.build ->
policy.evaluate -> ticket.issue -> execute -> audit.append -> render.reply
```

性能预算

阶段	预算	超限行为
注入筛查	< 5ms，同步正则	命中即短路返回红色决策
规则意图与引擎	< 20ms	无模型也可完成动作与知识问答
模型规划	p50 ≤ 3s，p90 ≤ 8s，上限 4 轮工具调用	超时返回 502 可重试，不进入伪回答
动作执行	< 150ms/节点（SQLite 事务）	失败写回执并计入熔断
审计写入	同步追加，链式哈希	写失败则动作不返回成功

3. Agent 意图理解与任务 DAG

意图识别分成规则层和模型层。规则层负责金额、手机号、日期、已知商户、页面和账户抽取；模型层处理同义表达、多轮省略和复合请求。两条路径最终都必须进入同一个 IntentValidator。

意图与计划结构

```
Intent = { name, confidence, slots, missing, evidence[], source }
TaskPlan = { planId, sessionId, intent, nodes[], digest, createdAt }
PlanNode = { id, dependsOn[], kind, tool, args, state, level, evidenceRefs[] }
```



节点只在依赖完成后进入 ready；确认/强验证节点会暂停 DAG。

图 2 订阅变更被拆成查询、取消、查询、开通四个节点；每个动作只能在依赖完成后继续。

证据绑定与反幻觉

计划中的 evidence
必须能在本次工具返回的事实语料中找到对应值，渲染前由服务端过滤无法佐证的条目；summary、actions 与 evidence 中的金额、日期、商户只允许来自工具结果，缺槽位时进入 needClarification
并只追问一个最关键的问题。对话历史以「不可信资料」角色注入，其中任何文字都不能成为系统指令。

工具面板动态裁剪

工具面板：五类查询工具与全部动作工具（转账、订阅开通/取消、缴费、自动批准、定时转账、界面、页面跳转、快捷服务）常驻，理财与贷款工具按话题注入；模型可直接调用动作工具执行业务，动作工具的执行结果只有 executed 才允许表述为已办理，needsPassword 只能生成确认票据；规则引擎继续兜底解析高频话术。

典型规划

用户表达	计划节点	执行结果
查上月收支并给节省意见	读账户 -> 读流水 -> 分类聚合 -> 生成建议	绿色查询链，结果引用数据库字段
关爱奇艺，开腾讯视频	查爱奇艺 -> 关续费 -> 查腾讯 -> 开续费	黄色动作暂停，分别签发确认票据
给林晓转 5000 元	查账户 -> 校验收款人 -> 风险评估 -> 强验证 -> 转账	红色节点等待强验证，成功后写入回执

状态机

```
RECEIVED -> NORMALIZED -> INTENT_RESOLVED -> SLOTS_FILLED
-> PLAN_PREVIEWED -> POLICY_CHECKED
-> WAITING_CONFIRM / WAITING_STRONG_AUTH -> EXECUTING
-> COMPLETED / PARTIAL_FAILED / CANCELLED / CIRCUIT_OPEN
```

4. 权限策略与安全设计

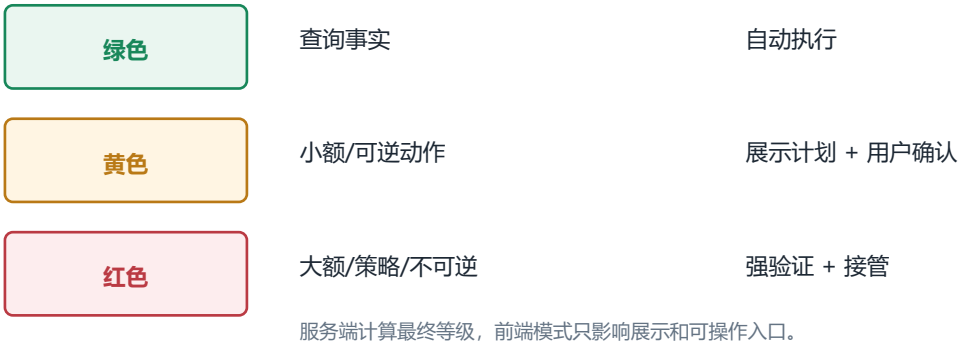


图 3 权限等级由服务端按计划节点计算；界面模式不能覆盖最终策略。

策略输入

因子	计算内容	影响
基础动作	查询、订阅、转账、挂失、理财	决定最低风险级别
金额	单笔金额与日累计金额	超过阈值升级 red
目标	本人账户、已知收款人、新收款人	新目标升级 red
可逆性	能否取消、退款或回滚	不可逆动作升级 red
用户策略	自动批准、阈值、内部互转、生活缴费	只影响策略允许范围
上下文	渠道、会话、票据、失败次数	决定是否熔断或需要接管

票据与强验证

黄色和红色动作都生成一次性票据。票据绑定 userId、channel、sessionId、planId、nodeId、工具名、参数摘要和过期时间。确认页面只提交票据与密码，服务端重新读取原始参数并比较 digest，避免用户通过修改请求体改变金额或收款人。

熔断与限流

同一渠道连续 5 次支付密码失败触发 circuit_open，15 分钟内拒绝该渠道资金动作；公开免口令部署下，AI 对话、模型自测与语音接口按 IP 限每 10 分钟 30 次，访客工作区创建限每 10 分钟 10 次。限流与熔断都写入审计，形成可解释的拒绝理由。

注入防御纵深

第一层是输入特征筛查：忽略指令、角色扮演、越狱关键词命中后直接短路，返回红色决策并写审计；第二层是提示词结构：系统提示词声明对话历史与界面上下文均为不可信资料；第三层是执行语义：模型输出的风险等级只作为建议，红色节点必须持票据与密码执行，策略引擎在服务端重算最终等级。

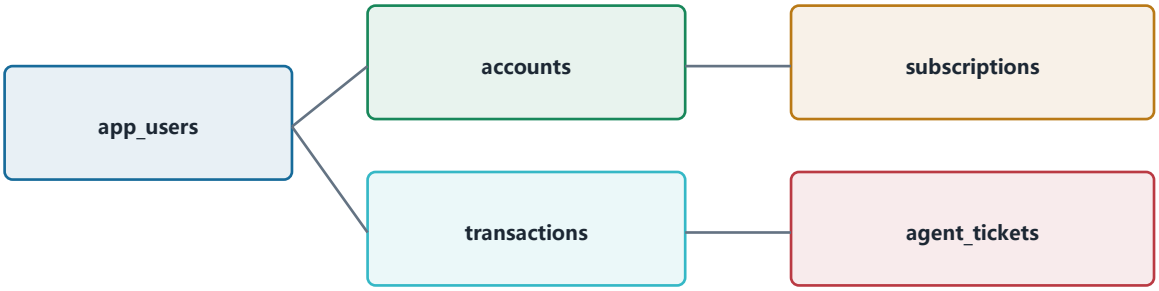
审计链

```
intent.received -> plan.created -> policy.decided -> node.paused
node.confirmed -> node.executed / node.failed -> receipt.created
[redacted]userId, channel, sessionId, messageId, planId, nodeId, level, decision, inputDigest, resultRef,
prevHash, hash
```

敌对性安全审查基线

攻击面	测试动作	必须成立的结果
提示词注入	忽略前面规则、要求输出系统提示词	模型不改变工具和策略白名单
参数污染	把 100 元确认改成 5000 元	digest 不匹配，节点不执行
重放	重复提交相同 messageId/ticketId	只返回缓存或 ticket_used
越权	用他人 userId/群聊确认	用户绑定校验失败
伪造回执	模型输出已转账但执行器失败	前端只显示执行器事实
状态错配	red 节点显示已拦截却又成功	状态词区分 blocked、waiting、executed

5. SQLite 金融档案与数据一致性



账户事实、流水、订阅和票据共享 userId；动作执行写回同一 SQLite 数据源。

图 4 核心表围绕 userId 和 accountId 连接，动作写回同一数据源，查询接口不在前端制造余额。

核心实体

实体	用途	关键约束
app_users	应用用户与策略	渠道用户必须映射到内部 userId
accounts	主账户、储蓄卡、信用卡和授信	容器账户不计入可支付余额
transactions	逐笔流水	2026-08-01 至 2026-10-23，200 条
subscriptions	固定订阅与续费状态	取消只改变未来扣款状态
agent_tickets	跨渠道确认票据	一次性使用，绑定摘要和过期时间
visitor_profiles	访客工作区登记	克隆模板用户，记录最后访问时间与容量
audit_log	动作与安全事件	写入渠道、计划、节点和结果引用

数据口径

备用金是储蓄目标，不作为账户余额；微信支付是绑定对象或扣款来源；信用卡是负债和支付来源；总资产、总负债、净资产和可用授信分开计算。流水按月份从 10 月向前展开，页面支持逐条明细和筛选。

访客工作区隔离

公开部署下每个浏览器或企业微信用户在首次访问时克隆模板用户，生成 v-/w-
前缀的独立工作区，后续请求由服务端强制注入 userId，客户端无法指定他人空间。总容量按字节 ×1.7 估算，超过 100MB 按 LRU
淘汰最久未访问的工作区；审计行在淘汰时保留，维持链式哈希连续。跨工作区转账在执行器入口直接拒绝。

一致性校验

```
opening + signed_flows + live_ledger = current_balance
internal_transfer has exactly two legs
transaction.account_id belongs to user_id
future_transactions = 0
credit_usage <= credit_limit
```

6. IM 渠道接入与跨渠道确认

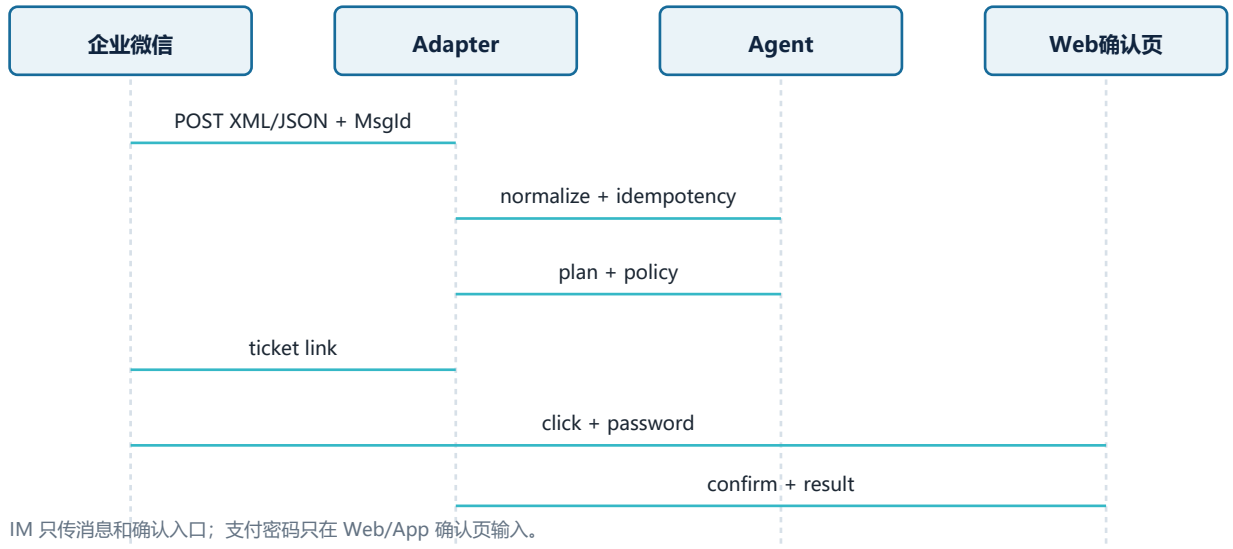


图 5 IM 适配器只负责收、转、发；密码和强验证回到 Web/App。

通用 Webhook

```
POST /channel/message
Content-Type: application/json
X-Channel-Signature: sha256=<hex>
X-Idempotency-Key: <provider-message-id>

{ userId, sessionId, messageId, text, page }
```

企业微信

GET 回调用于 Token、timestamp、nonce、msg_signature 和 echostr 校验；POST 读取 MsgType、FromUserName、CreateTime、MsgId、Content 和 AgentID，完成 providerUserId 到内部 userId 的映射。长任务通过 message/send 异步回执。

渠道	会话格式	幂等键	确认方式
Web	web:userId	requestId	页面卡片
Webhook	webhook:userId	X-Idempotency-Key	JSON 中 ticketId
企业微信私聊	wecom:userId	MsgId	短链接回 Web/App
企业微信群聊	wecom:group:chatId:userId	MsgId	强制点击确认页

确认协议

```
IM -> Agent: text
Agent -> IM: plan summary + ticket link
Web/App -> /api/agent/confirm: ticketId + password
Server: verify user/session/digest/expiry -> execute node
Server -> IM: resultRef + status + auditSeq
```

传输安全参数

通用 Webhook：HMAC-SHA256 签名，300 秒时间窗，32KB 体积上限，provider message id 作幂等键，重放只返回首次结果。企业微信：GET 完成 Token/timestamp/nonce/msg_signature/echostr 验签，POST 报文 SHA-1 验签后用 AES-256-CBC（PKCS#7）解密，AccessToken 缓存复用，5 秒内先 ACK、出站经 message/send
异步送达。两条渠道共享同一套策略引擎与票据协议，密码任何情况下不进入消息通道。

7. 语音与模型服务

对话模型通过 OpenAI 兼容接口调用，服务端只接受结构化意图和计划草案。语音播报优先走项目内 Qwen3-TTS 0.6B 服务，默认 Serena 音色，支持 9 个官方音色和中文语气指令。

服务	地址/入口	用途	当前验证
AI Chat	配置的 OpenAI-compatible base URL	意图和计划草案	健康检查接口
Qwen TTS	127.0.0.1:7861/v1/models	中文播报与语气控制	模型列表 + WAV 合成 200
SQLite	data/finance.sqlite	账户与业务事实	db:check
IM	/channel/message、/channel/wecom/callback	跨渠道消息	im:check

模型接入与降级

服务端默认接入硅基流动免费模型，保证开箱可用；使用者可在客户端配置自定义网关（DeepSeek、通义千问等 OpenAI 兼容服务），凭据经 base64 编码的 X-AI-Config
头单次转发，不入库、不写日志、不在接口回显。网关地址做协议与目标校验，拒绝内网与本机地址（SSRF 防护）。密钥缺失或上游异常时返回 502 可重试错误，前端展示失败原因并提供一键重试；系统不存在离线伪回答路径，展示中的每一条结论都必须能追溯到工具结果。

审查方法

敌对性审查以「攻击者能否让系统执行一笔未被用户明确授权的资金动作」为第一判据，以「评审者能否从回执判断真实状态」为第二判据。攻击路径覆盖：模型伪造 green 等级、确认请求改写金额与收款人、票据与 messageId 重放、跨用户与跨渠道确认、模型口述成功但执行器失败、失败后继续执行后续节点、red
状态词与界面标签错配。每条路径的验证结果与闭环状态见第 8 节。

8. 敌对性审查结果

审查以攻击者能否让系统执行一笔没有被用户明确授权的资金动作作为第一判据，以评审者能否从回执判断真实状态作为第二判据。下表按严重程度列出全部攻击路径：其中两项为审查中实际发现并已修复的缺陷，其余为经验证成立或明确记录的边界。

级别	攻击路径	验证结果	状态
高	服务重启后票据丢失（历史发现）	内存票据 map 在重启后清空，跨渠道确认会失败	已闭环：票据落库 agent_tickets，绑定 user/channel/session/message 与摘要，重放返回 ticket_used
高	定时转账执行分支引用越界变量（本轮发现）	schedule_transfer 曾引用不存在的请求体变量，触发即 ReferenceError 且无法生成回执	已闭环：改为一次性票据 + 支付密码确认路径，并纳入确认白名单
高	红色等待态被显示成「已拦截」	等待密码的节点与阻断节点共用文案，成功后又出现回执	已闭环：状态词拆分 blocked / waiting_strong_auth / executed，标签与执行状态分别渲染
高	模型输出等级覆盖服务端策略	构造模型对大额转账返回 green	防御成立：最终等级由服务端按节点、金额与归属重算，模型输出只作风险提示
中	确认请求参数污染	把 100 元确认请求改写成 5000 元	防御成立：服务端按票据重读原始参数并比对参数摘要，不一致即拒绝
中	跨用户 / 跨渠道确认	携带他人会话打开确认链接	防御成立：票据绑定会话与用户，返回 403 TICKET_SESSION_MISMATCH
中	多动作计划非原子执行	同一计划第一步成功后第二步密码失败	已知边界：按节点签发票据、逐节点确认；不做跨节点回滚，失败节点在回执中明确展示
中	静态资源与配置暴露	直接请求 .env、数据库文件与点号路径	防御成立：静态白名单之外一律 404，密钥只存在于服务端环境变量

答辩口径

系统的可信边界在服务端：模型负责理解和计划，策略引擎负责风险级别，执行器负责事实变更，审计链负责追溯。演示页面展示的是同一条服务端状态，不用界面标签代替执行结果。

9. 部署、测试与评审验收

评审机只需 Node.js 24+ 和浏览器即可启动 Web；SQLite 数据随项目提供。需要语音时启动 Qwen TTS 0.6B 服务，AI 对话使用配置的 OpenAI 兼容网关。

启动命令

```
cd ■■■■_■■■■■■
npm install
npm run db:check
npm start

# ■■■■
npm run check
npm run smoke
npm run db:check
npm run im:check
```

部署接口

接口	目的
GET /api/health	AI、TTS、数据库和版本状态
GET /api/finance/summary	总资产、负债、净资产和授信
POST /api/agent	自然语言 Agent 入口
GET /api/tts/health	Qwen3-TTS 提供方和音色
POST /channel/message	通用 Webhook
GET/POST /channel/wecom/callback	企业微信回调
POST /api/agent/confirm	票据确认和强验证

验收基线（版本化）

命令	覆盖	当前结果
npm run check	静态契约 + 接口行为与错误路径	通过
npm run smoke	浏览器端到端断言（Edge headless）	329/329
npm run im:check	Webhook 与企业微信通道、票据与幂等	55/55
npm run visitor:check	访客工作区隔离、容量淘汰与审计保留	25/25
npm run db:check	SQLite 数据口径与余额一致性	通过

提交结构

- 01 技术文档：本 PDF 以及 Markdown 源稿。
- 03 源代码与部署材料：index.html、server.mjs、db.mjs、SQLite、scripts、README 和部署说明。
- 本地模型权重、API Key、日志和临时文件不放入提交包；启动器通过环境变量接入服务。
- 提交前冻结数据库指纹、测试输出、版本号和截图，避免材料与代码状态不一致。

最终验收清单

类别	通过条件
架构	图中每一层能在代码或接口中找到对应落点
算法	规则和模型最终归一为 Intent，动作按 DAG 依赖执行
权限	绿/黄/红由服务端计算，票据防重放，红色强验证可见
安全	注入、参数污染、重放、跨用户确认、伪造回执均失败
数据	200 条流水、账户余额、订阅、授信和审计一致
IM	Webhook 和企业微信使用同一 Envelope、策略和票据
视觉	架构图、流程图、数据图和 IM 序列图清晰可读
文件	PDF 小于 50MB，源代码和部署材料可复现

文档版本：1.1 · 2026-10-31 · 对应验收基线 smoke 329 条